TEMPLATE P47 · DATA PROTECTION IMPACT ASSESSMENT

Data protection impact assessment

Documents the data protection impact assessment (DPIA) of a processing operation that embeds AI: what is processed and why, whether it is necessary and proportionate, what risks it creates for people and which measures reduce them before it starts.

Fernando García Varela Version 0.1 (working draft) 19-09-2026 Draft for review

IN THIS DOCUMENT

01 Instructions for use

02 Identification

03 Reason for the assessment

04 Systematic description of the processing

05 Necessity and proportionality

06 Assessment of the risks to rights and freedoms

07 Planned measures

08 Consultation of the data protection officer

09 Conclusion and prior consultation

10 Relationship with other assessments

11 Review

12 Quality criteria

13 Approval and verification

14 Version control

> *This template does not constitute legal advice.* References consulted in September 2026; verify that they are current (document 34 §6).

Legal notice and disclaimer. SEVEN-G is a reference methodological framework provided "as is" and for information purposes only. It does not constitute legal, regulatory, financial or professional advice, nor does it guarantee compliance with any law or standard. References to general regulation (such as the EU AI Act, the GDPR, DORA or NIS2), to technical standards and to regulation specific to each sector or jurisdiction may be incomplete, may not apply to a particular case or may become out of date as a result of regulatory changes, interpretations or supervisory positions after their consultation date. **Each organisation that uses SEVEN-G is solely responsible for identifying the regulation that applies to it, verifying that it is current and certifying its own regulatory compliance**, with the appropriate qualified advice. This methodology is a generic, free aid shared with the community so that nobody has to start from scratch; each person or organisation can and should adapt it to its own use. It must not be inferred that its legally sensitive parts have been reviewed by legal counsel: those reviews, for each company or sector, are the ultimate responsibility of the company, consultant or organisation that uses it. Although every effort is made to keep it up to date, some regulation may have changed without being reflected here. To the fullest extent permitted by law, the author accepts no responsibility whatsoever for the effects of its application in any organisation or for its full applicability. The methodology does not grant certification of any kind. The author accepts no liability for any use made of this content or for any decisions taken on the basis of it. The data, figures, companies and cases in the examples are fictitious or illustrative.

Why it matters. Where it is mandatory, the DPIA must exist before the processing starts (GDPR, Article 35) and it is a condition of G3 and G4 in SEVEN-G. Without it, an AI system can reach production processing data without a clear legal basis, with unforeseen inferences or automated decisions and without proportionate measures; the result is a regulatory and reputational risk that can no longer be corrected in the design, only by suspending the system. This template turns the conclusion of P11 §9.1 ("required") into a complete and verifiable assessment, integrated into the risk register (P12).

01

Instructions for use

Aspect	Guidance
When it is used	It is opened when P11 §9.1 concludes that the assessment is **Required** (or **Recommended** and the company decides to carry it out). It is prepared in phase 3, before G3; it is updated in phase 4 with the design (G4) and reviewed at every R6 and upon any change listed in section 11. Always before the processing starts.
Who completes it	The controller, coordinated by the AI Risk Owner (32 §6.1). The AI Product Owner and the AI Technical Owner provide the description of the processing and the measures.
Who verifies it	Lite: AI Office or AI Auditor. Enterprise: AI Auditor. The data protection officer advises and monitors, but is not listed as author (document 30; GDPR, Article 39).
Who decides or approves	The controller, in the body corresponding to the residual risk (section 9 and P12 §6). Prior consultation with the supervisory authority is decided by the same body when applicable.
Gate or moment	Feasibility (exists or has been started with closure before G4, G3.09); G4 · Design (completed and measures in the design, G4.13); R6 (current, R6.08). (G3)
Tool	T07 · Regulatory classifier (status, date and link of the assessment in the system record, 32 §3.5).
Reference document	32 §6.1 (when and who), 34 §6.1 and §6.2 (articles and guidelines), document 33 (risk scales), document 51 (data).
Lite versus Enterprise	Lite may omit the fields marked **(Enterprise)**. If the DPIA is mandatory, its minimum content is the same in both.

Completion rules:

- **One assessment per processing operation.** If several AI systems (SIA-AAAA-NNN) share a processing operation, they are assessed together; if one system has different processing operations (for example, training and use), they are described separately in section 4.
- The template may be replaced by the company's own methodology if it covers all the blocks; in that case it is linked and only sections 2, 9 and 13 are completed.
- Risks are assessed with the **common scale** (common specification §5.1, document 33) and those of Medium level or above are carried over to **P12** with their code IA-AAAA-NNN · Rnn.
- Supporting guidance: the EDPB-endorsed Guidelines on data protection impact assessment (WP248 rev.01), the lists of processing operations requiring an assessment published by the AEPD and the Guides of the AEPD (Spanish Data Protection Agency) on processing operations that incorporate AI and on auditing such processing.

02

Identification

Field	Content	Guidance
Use case code		IA-AAAA-NNN.
AI systems included		SIA-AAAA-NNN from P05 (T02).
Name of the processing operation		As it appears, or will appear, in the record of processing activities (GDPR, Article 30).
Controller		Group company that determines the purposes and means.
Processors		Suppliers that process data on behalf of the company (P14).
Reference to P11		Version and date of the classification that concluded that the DPIA is necessary.
Data protection officer		Name or function.
Document version		
Date		DD-MM-AAAA.
Status		Draft · Under consultation with the data protection officer · Submitted for verification · Approved · Under prior consultation · Superseded.

03

Reason for the assessment

Copy the answers from P11 §9.1 and add the justification. A single "Yes" makes the assessment mandatory.

Criterion	Yes · No	Justification
Systematic and extensive evaluation of personal aspects based on automated processing, including profiling, on which decisions with legal or similarly significant effects are based (Article 35.3.a)		
Large-scale processing of special categories of data or of personal data relating to criminal convictions and offences (Article 35.3.b)		
Systematic monitoring of a publicly accessible area on a large scale (Article 35.3.c)		
It appears on the lists of processing operations requiring an assessment of the competent supervisory authority		State the type of processing on the list.
Other indications of high risk under WP248 rev.01 (for example, innovative use of technology, combination of datasets, vulnerable persons)		
Decisions based solely on automated processing with legal or similarly significant effects (Article 22)		If "Yes", section 5 must demonstrate the applicable exception and its safeguards.

04

Systematic description of the processing

4.1 Purposes and context

Field	Content	Guidance
Purpose or purposes		Specific and explicit. Consistent with the intended purpose in P05 and P11.
Business process in which it sits		In plain language (P31).

Field	Content	Guidance
Role of AI in the processing		What the system does with the data: classify, score, generate, recommend, decide. Autonomy level A0–A3.
Are there decisions about people?		Which decisions, who takes them and with what oversight (P17).
Interest or benefit pursued		For the company, for the data subjects or for third parties.

4.2 Data and data subjects

Field	Content	Guidance
Categories of data subjects		Customers, employees, candidates, citizens, minors or other vulnerable groups.
Approximate number of data subjects		Order of magnitude and geographical scope.
Categories of data		Identification, contact, financial, behavioural, free content (text, voice, image).
Special categories or criminal data		Which and why they are necessary.
Data inferred or generated by the system		Scores, profiles, summaries, inferred categories. They are also personal data.
Sources		From the data subject, internal systems, third parties, public sources.

4.3 Data lifecycle

Stage	What data	Where and who processes them	Retention	Guidance
Training or fine-tuning				Only if the company trains or fine-tunes a model (P16).
Testing and validation				Test data, anonymised or pseudonymised where possible.
Use in production (inputs and outputs)				Includes prompts, retrieved context and logs.

Stage	What data	Where and who processes them	Retention	Guidance
Logs and traceability				Consistent with the log retention periods (32 §3.5).
Retirement				Retention, deletion or transfer (P30).

4.4 Technology and third parties

Field	Content	Guidance
AI model or models		Own, third-party via API, fine-tuned. Supplier and version (P15, P16).
Use of the data by the supplier for training		No · Yes · No data (32 §3.6).
Location of the processing		European Economic Area · Outside with appropriate safeguards · No data.
Information from the system provider used (Enterprise)		If the company is the deployer of a high-risk system, the information under Article 13 of the AI Act that has been used (Article 26.9).

05

Necessity and proportionality

Aspect	Content	Guidance
Legal basis (Article 6)		One per purpose. Confirmed by the data protection function (G3.03).
Condition for special categories (Article 9)		Including processing to detect and correct bias, with its conditions (34 §3.2, document 51).
Purpose limitation		How use for other purposes is prevented.
Data minimisation		Which data have been discarded and why the remaining ones are necessary.
Accuracy		How inaccurate data or outputs are prevented from affecting people.
Storage limitation		Periods per stage (section 4.3).

Aspect	Content	Guidance
Is AI necessary for this purpose?		Less intrusive alternatives considered, including the non-AI alternative (P06).
Information to data subjects (Articles 13 and 14)		Including the existence of automated decision-making and meaningful information about the logic involved (P49).
Exercise of rights		Access (including Article 15.1.h), rectification, erasure, objection; how they are handled when the data are in a model or in logs.
Safeguards for automated decisions (Article 22)		Applicable exception; human intervention, expressing one's point of view and contesting the decision (P17 §8).
Processors and contracts		Data processing agreement and supplier terms (P14).
International transfers		Applicable safeguards.

06

Assessment of the risks to rights and freedoms

Assess each risk from the point of view of the people, not the company. The dominant impact axis will usually be "People and rights" (P12 §3.2). **Level = Likelihood × Impact**: Low 1–4 · Medium 5–9 · High 10–15 · Critical 16–25.

Risks worth reviewing in processing that embeds AI: unauthorised access or disclosure (including data leakage through prompt injection or model memorisation); inferences the data subject does not expect; biased or discriminatory outputs; inaccurate decisions affecting the person; re-identification of pseudonymised data; loss of the data subject's control over their data; practical impossibility of exercising rights; reuse for other purposes; excessive observation or tracking.

No.	Risk to people (cause, event and consequence)	Data subjects affected	Inh. L	Inh. I	Inherent level	Measures (section 7)	Res. L	Res. I	Residual level	Code in P12
E01			1–5	1–5	Low · Medium · High · Critical	M..				IA-AAAA-NNN · Rnn
E02										
E03										

No.	Risk to people (cause, event and consequence)	Data subjects affected	Inh. L	Inh. I	Inherent level	Measures (section 7)	Res. L	Res. I	Residual level	Code in P12
***(illustrative example)* E01**	An assistant that classifies customer complaints infers health data from the free text and stores them in the logs, without a legal basis for that processing.	Customers who complain	4	4	16 Critical	M01, M02	2	3	6 Medium	IA-2026-014 · R03

07

Planned measures

No.	Measure	Risks addressed	Type	Where it is implemented	Owner	Status
Finding your way around the site `(M01)`		E..	Technical · Organisational · Contractual	P15 · P16 · P17 · P18 · P24 · P49 · P14		Planned · Implemented · Verified
What SEVEN-G is and what problem it solves `(M02)`						
***(illustrative example)* M01**	Filter that detects and masks health data before the log is stored; log retention limited to 6 months.	E01	Technical	P16, P24	AI Technical Owner	Implemented
***(illustrative example)* M02**	Notice in the complaint form that health data should not be included unless necessary for the complaint.	E01	Organisational	P49	AI Product Owner	Planned

A measure only reduces the residual risk if it exists and works (P12). "Planned" measures must be implemented before the processing starts; otherwise the risk is assessed without them.

08

Consultation of the data protection officer

Field	Content	Guidance
Date of the consultation		Before approval.
Opinion of the data protection officer		Summary or reference to the report.
Recommendations		One per row if there are several.
Are the recommendations followed?		Yes · Partially · No. If not followed, reason and who decides.
Views of data subjects or their representatives (Enterprise)		Where appropriate and possible; if not sought, reason.

09

Conclusion and prior consultation

Field	Content	Guidance
Highest residual level		From section 6.
Conclusion		The processing may start · May start with conditions · May not start.
Conditions		Measures that must be verified and date.
Is prior consultation with the supervisory authority required (Article 36)?		Yes, if the residual risk remains high despite the measures. In SEVEN-G, in addition, High or Critical residual risk with its level of acceptance (32 §6.1; document 30 §7.2).
Competent supervisory authority		In Spain, the Spanish Data Protection Agency .
Date of the prior consultation and response		The processing does not start until the response has been received or the applicable period has elapsed.

Field	Content	Guidance
Acceptance of the residual risk		Body according to P12 §6. A Critical residual without approval from the board or its board committee blocks G3 and G5.

10

Relationship with other assessments

Assessment	Applies?	How it is coordinated
Fundamental rights impact assessment (P48)	Yes · No	It complements the DPIA without duplicating it (Article 27.4 of the AI Act): the description of the processing and the data protection risks are reused.
Use case risk register (P12)	Yes	Risks E.. of Medium level or above appear in P12.
Security design (P18)		Technical data security measures.
Sector-specific or third-party assessments (Enterprise)		DORA , NIS2 or others (P11 §9.3).

11

Review

The assessment is reviewed at every R6 and, in addition, whenever any of these elements changes: purpose, categories of data or of data subjects, sources, model or supplier, autonomy level, scope of decisions about people, location of the processing or the authority's position. The change is recorded in P27.

Date	Reason	Changes to the assessment	Resulting residual level	Reviewed by
	Change · Incident · Authority's position (R6)			

12

Quality criteria

The formal criteria are in document 21 (G3.03, G3.09, G4.13 and R6.08).

#	Check	Status
1	The reason for the assessment matches P11 §9.1 and is justified.	Met · Not met · Not applicable · Pending
2	The description covers purposes, data, data subjects, data lifecycle, technology and third parties.	
3	Each purpose has a legal basis confirmed by the data protection function (G3.03).	
4	The necessity of AI and the least intrusive alternative have been analysed.	
5	Risks are assessed from the people's perspective, with the common scale, inherent and residual, and those of Medium level or above are in P12.	
6	Each risk has measures with an owner; the measures that reduce the residual are implemented.	
7	The opinion of the data protection officer and what was done with it are recorded.	
8	A reasoned decision has been taken on prior consultation.	
9	The assessment predates the start of the processing and its measures are incorporated into the design (G4.13).	
Sphere map and ambition levels (10)	It is current at the latest R6 (R6.08).	

13

Approval and verification

Function	Role in SEVEN-G	Name and position	Date	Signature or reference
Coordinates and prepares	AI Risk Owner, on behalf of the controller			
Provides description and measures	AI Product Owner and AI Technical Owner			
Advises and monitors	Data protection officer			
Verifies	AI Office or AI Auditor (Lite) · AI Auditor (Enterprise)			
Approves and accepts the residual	Body according to P12 §6			
☐ **Statement: "The organisation confirms that this assessment has been carried out with qualified advice and accepts responsibility for it; SEVEN-G is only a methodological reference."**	Same body that approves			

Segregation of duties: the data protection officer is neither the author of the assessment nor approves it; whoever prepares it does not verify it.

14

Version control

Completed document

Version	Date	Author	Changes

Template

Version	Date	Changes
0.1	19-09-2026	First version. Develops the assessment that P11 §9.1 declares necessary, with the content of 32 §6.1 and 34 §6.1, the common risk scales and the link with P12 and P48. References consulted in September 2026.

External sources cited

Links to the official or primary source, checked before publication. Always verify the version in force on the date of use.

Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union (NIS 2 Directive) · https://eur-lex.europa.eu/eli/dir/2022/2555/oj/eng · Parlamento Europeo y Consejo de la UE · 14-12-2022

Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) · https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng · Parlamento Europeo y Consejo de la UE · 27-04-2016

Regulation (EU) 2022/2554 of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector (DORA) · https://eur-lex.europa.eu/eli/reg/2022/2554/oj/eng · Parlamento Europeo y Consejo de la UE · 14-12-2022

Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act) · https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng · Parlamento Europeo y Consejo de la UE · 13-06-2024

European Data Protection Board (EDPB) · https://www.edpb.europa.eu/edpb_en · Comité Europeo de Protección de Datos (organismo de la UE creado por el art. 68 del RGPD)

Spanish Data Protection Agency (Agencia Española de Protección de Datos, AEPD) · https://www.aepd.es/en · Agencia Española de Protección de Datos

AEPD guides on processing that embeds AI: «GDPR compliance of processing that embed Artificial Intelligence. An introduction» (February 2020) and «Audit Requirements for Personal Data Processing Activities involving AI» (January 2021) · «Innovation and Technology» page

listing both · https://www.aepd.es/en/areas/innovation-and-technology · Agencia Española de Protección de Datos

Guidelines on Data Protection Impact Assessment (DPIA) and determining whether processing is "likely to result in a high risk" for the purposes of Regulation 2016/679 (WP248rev.01), Article 29 Working Party, endorsed by the EDPB · https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/data-protection-impact-assessments-high-risk-processing_en · Grupo de Trabajo del Artículo 29; asumidas por el Comité Europeo de Protección de Datos (25-05-2018) · 04-10-2017

List of the types of data processing that require a data protection impact assessment (Art. 35(4) GDPR) · https://www.aepd.es/documento/listas-dpia-en-35-4.pdf · Agencia Española de Protección de Datos · 06-05-2019